

Project Charter

IT Risk & GRC Home Lab | MapleCare Health Services

1. Project Name

IT Risk & GRC Home Lab: Risk Assessment, Control Mapping, and Remediation Dashboard

2. Background

MapleCare Health Services is a fictional healthcare organization in Canada with approximately 150 employees. The organization uses Microsoft 365, SharePoint, a patient records system, an HR system, staff laptops, and a third-party billing platform to support daily operations.

Because the organization handles patient records, employee information, billing data, and internal business documents, it needs a clear way to understand its main IT and cybersecurity risks. Leadership wants to know which risks are most serious, what controls are already in place, where the gaps are, and what actions should be taken first.

This project simulates the work I would perform as a junior IT Risk and GRC Analyst supporting that assessment.

3. Project Objective

The goal of this project is to assess key IT risks at MapleCare Health Services and prepare practical GRC documentation that can support management decision-making.

The project focuses on identifying important systems and processes, documenting risks, scoring those risks, mapping them to security controls, identifying evidence needed for audit readiness, tracking remediation actions, and summarizing the results in a dashboard.

4. My Role

My role is to act as a Junior IT Risk and GRC Analyst. In this role, I am responsible for:

- Understanding the business environment
- Identifying key IT systems and business processes
- Documenting cybersecurity, compliance, vendor, and operational risks
- Scoring risks based on impact and likelihood
- Mapping risks to NIST CSF 2.0, NIST SP 800-53, and ISO/IEC 27001:2022 controls
- Defining evidence needed to validate controls
- Tracking remediation actions and ownership
- Preparing a dashboard for management review

Fictional portfolio project - no real patient, employee, or company data used

5. Scope

5.1 In Scope

Area	Description
IT asset and process inventory	Identify key systems, data types, business owners, and criticality
Risk assessment	Identify and score IT, cybersecurity, vendor, and operational risks
Risk register	Document risk descriptions, owners, ratings, treatment plans, and status
Control mapping	Link risks to relevant NIST and ISO controls
Evidence checklist	Define what evidence would be needed to prove controls are working
Remediation tracker	Track gaps, owners, action plans, due dates, and closure evidence
Dashboard	Summarize key risk information for management

5.2 Out of Scope

Area	Reason
Penetration testing	This project focuses on GRC and risk management, not offensive security testing
SOC monitoring	This project does not include live alert monitoring or incident investigation
Real patient data	All data used in the project is fictional
Legal advice	This project does not provide legal or regulatory advice
Production system changes	No real systems are accessed or changed

6. Key Stakeholders

Stakeholder	Role	Main Concern
Senior Management	Reviews risk results and approves priorities	Wants a clear view of the highest risks
IT Manager	Owns technical controls and remediation work	Wants realistic action plans and timelines
Clinic Manager	Owns the patient records process	Wants patient information protected
HR Manager	Owns onboarding, offboarding, and employee records	Wants user access managed properly
Finance Manager	Owns the billing vendor relationship	Wants billing and payment data protected
Operations Manager	Supports business process coordination	Wants risks documented clearly and operations protected

7. Frameworks Used

Framework	Purpose
NIST CSF 2.0	Used to organize cybersecurity risks and controls into clear categories
NIST SP 800-53	Used to reference detailed security and privacy controls
ISO/IEC 27001:2022	Used to align the assessment with a recognized information security management standard

8. Final Deliverables

Deliverable	Description
Project Charter	Defines the project purpose, scope, role, stakeholders, and expected outputs
Company Profile	Describes the fictional organization and business environment
Asset and Process Inventory	Lists key systems, owners, data types, and risk levels
Risk Register	Documents risks, impact, likelihood, ratings, owners, treatment, and status
Control Mapping Matrix	Maps risks to relevant NIST and ISO controls
Control Testing and Evidence Checklist	Defines how controls could be tested and what evidence would be needed
Remediation Tracker	Tracks gaps, action plans, owners, due dates, and closure evidence
Executive Dashboard	Summarizes risk status, open findings, overdue items, and ownership
Final Report	Presents key findings, risk themes, and recommendations

9. Success Criteria

This project will be successful if it clearly shows how I can support a GRC team in assessing IT risks, documenting controls, identifying gaps, tracking remediation, and reporting risk information to management.

The final portfolio should be practical, easy to understand, and close to the type of work expected from an entry-level IT Risk, GRC, Compliance, or IT Audit Analyst.

10. Project Status

Item	Status
Status	In Progress
Current Stage	Risk Register Development
Completed Deliverables	Project Charter, Company Profile, Asset and Process Inventory
Next Deliverable	Risk Register